FILE S1-KESTREL · TRACK 03 SUBMISSION · TEAM, CHALLENGE & SOLUTION

Money can’t move on a forged instruction.

VeriFi holds a risky payment until the person the instruction claims to come from confirms it on their own phone, with a passkey bound to that exact amount and account. The employee being deceived is never the one asked.



PAYMENT HELD
evidence signed & chained

EXHIBIT F · PRODUCT FILM
Watch the 60-second film

ASSIGNED TO	**VeriFi AI**
TEAM	Priyanshi Chittora · Kashish Yadav · Hardik Tailor · Jayant Kumawat
CHALLENGE	**Track 03:** help people and institutions verify financial communications, detect manipulation, and create an actionable path for review, reporting, or response.

EXHIBIT SET A · USER, THREAT SCENARIO & HARM

A deepfaked CFO can talk honest staff into wiring crores.

09:12 · INBOX

1 Lookalike email

From kestrelinfra-group.co, not kestrelinfra.com. The attacker owns the domain, so SPF, DKIM and DMARC all pass.

11:30 · ZOOM

2 Deepfake call

A face- and voice-cloned "CFO": *"Confidential acquisition. Pay today, tell no one."*

11:52 · ERP

3 New account

₹5 Cr to "Meridian Advisory LLP", an account the company has never paid before.

12:05 · NET BANKING

4 Money leaves

The convinced AP maker releases it. Recovery depends on reporting within hours.

the employee WAS suspicious ↓

WHO WE PROTECT

AP — **AP / treasury maker**
The deceived user. Releases payments; needs zero friction on normal days.

CFO — **CFO / authority**
The impersonated person. Confirms or denies in seconds, from anywhere.

FA — **Fraud analyst**
Investigates holds; must report to 1930 within the golden hour.

THE HARM, IN THE PUBLIC RECORD · ARUP, HONG KONG, JAN 2024

US$25.6M

taken after a video call with a deepfaked CFO and colleagues.

15 transfers · **5** accounts · **~1 week** before anyone checked

Caught only when the employee checked with HQ. Source: SCMP, May 2024.

RECONSTRUCTION · CURRENT JOURNEY, PRODUCT FLOW & DIFFERENTIATION

VeriFi connects the conversation to the payment.

TODAY fraud succeeds	Lookalike email passes SPF / DKIM	→ Deepfake “CFO” on Zoom	→ AP releases ₹5 Cr in net banking	→ Bank executes with no context	→ **Found days later. Money gone.**
WITH VERIFI fraud held	Email + meeting ingested into lineage graph	→ Release request hits the VeriFi gate	→ Account traced to a new lookalike domain	→ Real CFO’s phone: **Deny**	→ **Held. Evidence sealed. 1930 pack ready.**

Detectors score the call. Payee checks verify the account. VeriFi verifies the instruction.

APPROACH	SEES THE INSTRUCTION?	SEES THE PAYMENT?	HOLDS A PERFECT DEEPFAKE?	PROOF FROM THE REAL AUTHORITY?
Deepfake detectors (e.g. Reality Defender, Pindrop)	◐ Partial: media only	✗ No	✗ No	✗ No
Email security / BEC filters	◐ Partial: email only	✗ No	✗ No	✗ No
Payee verification (e.g. Eftsure)	✗ No	✓ **Yes**	◐ Flags unknown payees	✗ No
RBI name lookup (NEFT / RTGS, 2025)	✗ No	✓ **Yes**	✗ Fraudster supplies the name	✗ No
VeriFi AI	✓ **Lineage graph**	✓ **Release gate**	✓ **Provenance + passkey**	✓ **Transaction-bound**

INVESTIGATION METHOD · CORE DETECTION & DECISION APPROACH

Every fraud ends in an account, so we trace the account.

1 Trace

Where did this beneficiary account first enter the company?

- kestrelinfra-group.co · 4 days old
- Email: “confidential acquisition”
- Zoom: external “CFO”
- A/c ••7812 first seen in that email
- **₹5 Cr payment to A/c ••7812**

— Mail headers, Indian account / IFSC parsers

— Domain intel: lookalikes + registration age

— Claude on Bedrock adds intent; it can raise risk, never lower it

2 Decide

Do explicit rules or the bounded score demand more assurance?

$$R = 100 \times (1 - \prod (1 - \max w_i \cdot s_i))$$

noisy-OR over signal groups, always 0–100

R1	New beneficiary, ≥ ₹10 L
R2	Account first seen in an outside message
R3	Vendor bank details recently changed
R4	Outsider claims to be an executive
R5	Several young accounts paid in 7 days
R6	Asked to bypass normal process
R7	Dependency down: fail safe

3 Confirm

Who must confirm, and how strongly?

T0	Pass: released, no friction
T1	One authority approves
T2	Two approve + cooling-off

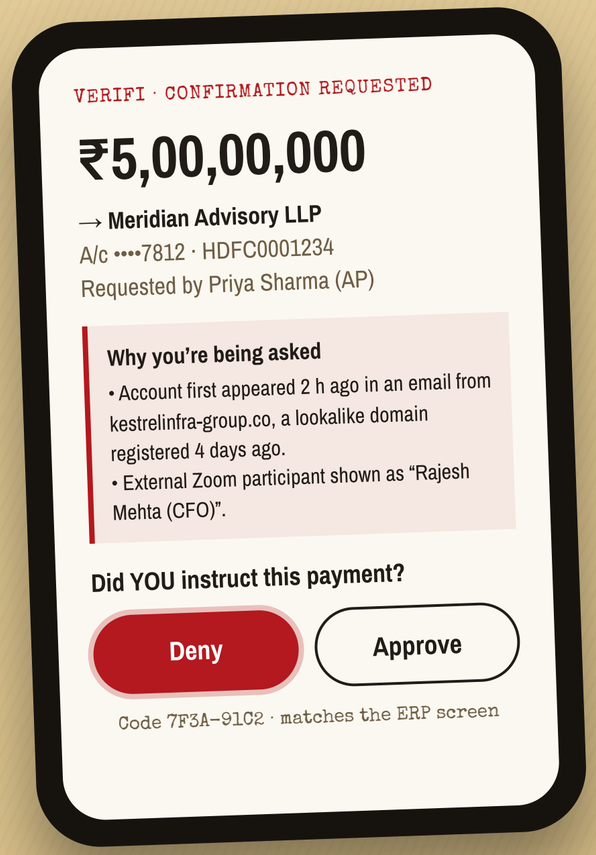
`Confirmers = approval matrix ∪ claimed authority − requester`

Any Deny or timeout → **held for human review**. The machine never auto-rejects.

R4, R5, and R2 with a lookalike or new domain → T2; the rest → T1. Rules decide, so every outcome is auditable; the score explains it.

PRODUCT FLOW · AUTHORITY CONFIRMATION

The real CFO confirms on their own phone.



↑ *the real Rajesh taps Deny*

1 **Routed to the authority**

Confirmers come from the customer's approval matrix plus whoever the message claims to be. The requester is always removed.

2 **Bound to this transaction**

`challenge = SHA-256(transaction ‖ decision ‖ nonce)`. The signature covers amount, account and the Approve / Deny choice.

3 **What you see is what you sign**

The prompt is rendered from the exact object that was hashed. Cancel is never Approve.

4 **Deny becomes a case**

Payment held, incident opened, evidence signed, 1930 pack ready in under two minutes.

> **A fraudster can fake the CFO's face and voice. They can't produce the CFO's passkey signature.**

LAB REPORT · DECISION IN ACTION (WORKED EXAMPLE)

Detector fooled. Payment still held.

SCENARIO S1 · CONTRIBUTION OF EACH SIGNAL GROUP TO THE RISK SCORE (W·S)



SCENARIO S1 · ₹5 CR TO A NEW ACCOUNT

87.5 / 100 risk

TIER T2
two confirmations + cooling-off

Rules fired: R2 lookalike + young domain · R4 external "CFO" · R1 new beneficiary · R6 secrecy

OTHER SCENARIOS (SAME POLICY)	SCORE	OUTCOME
S2 · Vendor bank-detail change from a real but compromised mailbox, ₹18 L	59.0	T1 + vendor callback
S3 · Routine payment to a known vendor account	6.0	T0, no prompt
S4 · "CEO on WhatsApp", new account typed in, ₹40 L	25.0	T1 via rule R1

Even with no meeting data at all

Score 79.1, and rule R2 alone still requires T2. The detector is optional; the decision isn't.

100 × (1 − 0.55 × 0.50 × 0.76 × 0.60) = 87.5 · weights are documented priors, calibrated in pilot shadow mode

CHAIN OF CUSTODY · DATA, EVIDENCE, VALIDATION PLAN & KEY ASSUMPTIONS

Synthetic data in, verifiable evidence out.

A · DATA

— **Prototype:** synthetic only. A fictional company (Kestrel Infra) with people, vendors, emails, meetings and payments.

— **Public:** news reports of the Arup case. No bank, customer or platform data.

— **Production:** customer-authorised finance mailboxes, meeting metadata and ERP data under a DPA.

B · EVIDENCE

— Every decision, passkey signature and analyst action is a hash-chained, append-only record.

— Chain heads signed with AWS KMS, stored under S3 Object Lock; an independent verifier re-checks it all.

— Output: 1930 / cybercrime.gov.in incident pack + bank recall draft.

C · VALIDATION PLAN

— 14 red-team regressions: forged or replayed passkeys, cross-payment release, prompt injection, fail-open, tenant leaks.

— 7 end-to-end scenarios asserting exact scores (S1 87.5 · S2 59.0 · S3 6.0 · S4 25.0).

— LLM eval: ≥ 90% field accuracy on 40 emails · decision p95 ≤ 300 ms · 60-day pilot shadow mode.

D · KEY ASSUMPTIONS

— Payments pass a release step we can hook: an ERP API call or the bank-upload file.

— Each authority enrolls a passkey on their own phone.

— If the account never appears in an ingested channel, rule R1 still forces confirmation. Weights stay expert priors until pilot calibration.

PROTOCOL · PRIVACY, SECURITY, SAFETY & MISUSE SAFEGUARDS

Private, secure, safe, and hard to misuse.

01 / PRIVACY

Privacy

- Account numbers, IFSC and phones tokenized (HMAC) before any LLM or graph
- Raw values only in an encrypted vault; analyst reads are logged
- Aadhaar detected and dropped
- Finance mailboxes only; India region; built for the DPDP Act 2023

02 / SECURITY

Security

- FIDO2 passkeys for every human, no passwords
- Challenge bound to transaction + decision; single-use
- Signed ERP calls and webhooks; tenant isolation
- Dependency down → high-value payments step up

03 / SAFETY

Safety

- Never auto-rejects: people decide every hold
- Every decision explained: rules fired + signal contributions
- The LLM can add risk, never remove it
- Requesters can't confirm their own payment

04 / MISUSE

Misuse

- Purpose-limited by contract: no HR or productivity monitoring
- Rogue enrollment blocked: one-time admin link, user alerted, two admins to replace
- Detailed signals go to confirmers, not requesters
- VeriFi prepares reports; humans file them

DESIGN RULE VeriFi can delay a payment. It can never move money, reject a payment, or accuse a person. People make every final call.

FIELD PLAN · DEPLOYMENT PATHWAY

Sold to the CFO, installed where payments are released.

INTEGRATION PATH

PROTOTYPE

Mode A · ERP pre-release API hook

The ERP calls VeriFi before releasing. T0 returns instantly; T1 / T2 return pending, then a signed callback.

→

PILOT

Mode B · Bank-upload file gate

VeriFi sits between the ERP's bank file and the bank (host-to-host / SFTP). No ERP code change.

→

PARTNERSHIP

Mode C · Bank-side checker

A bank offers VeriFi inside corporate net banking as the checker step for its business clients.

ROLLOUT

Hackathon · 48 h
Prototype on synthetic data: the full S1 scenario end to end on a real phone over HTTPS.

Pilot · 60 days
1–2 Indian enterprises. Shadow mode first (alert only), then hold mode; AWS Mumbai region.

Product
Graph / Gmail and Zoom / Teams connectors, Web Push, Secure Payment Confirmation, shared mule-account intel.

CUSTOMER

Indian mid-to-large enterprises with central treasury / AP

BUYER

CFO buys; CISO approves; AP and authorities use it

PRICING (HYPOTHESIS)

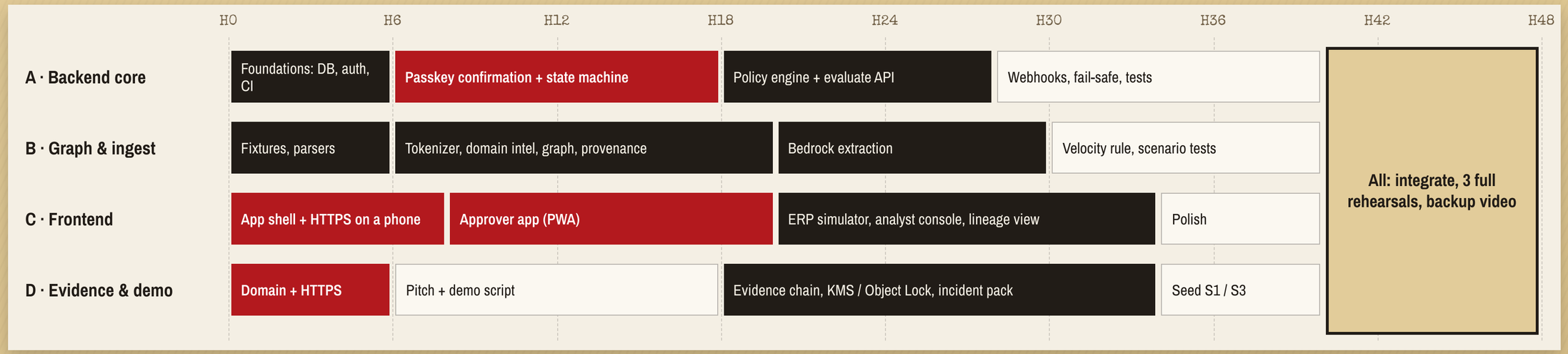
Per legal entity + payment-volume tier

PILOT TARGETS

< 3% step-up rate · < 60 s median confirmation · pack < 2 min

OPERATION TIMELINE · 48-HOUR PROTOTYPE PLAN

48 hours: build the confirmation spine first.



◆ H6 Passkey works on a phone over HTTPS ◆ H30 S1 runs end to end ◆ H44 Feature freeze

Critical path · Core build · Support

BUILT FOR REAL

Passkey protocol · lineage graph · policy engine · evidence chain · incident pack · ERP hook API

SIMULATED, LABELLED IN THE UI

ERP and bank · meeting feed · deepfake score (slider) · domain-age data for the demo domains

DONE MEANS

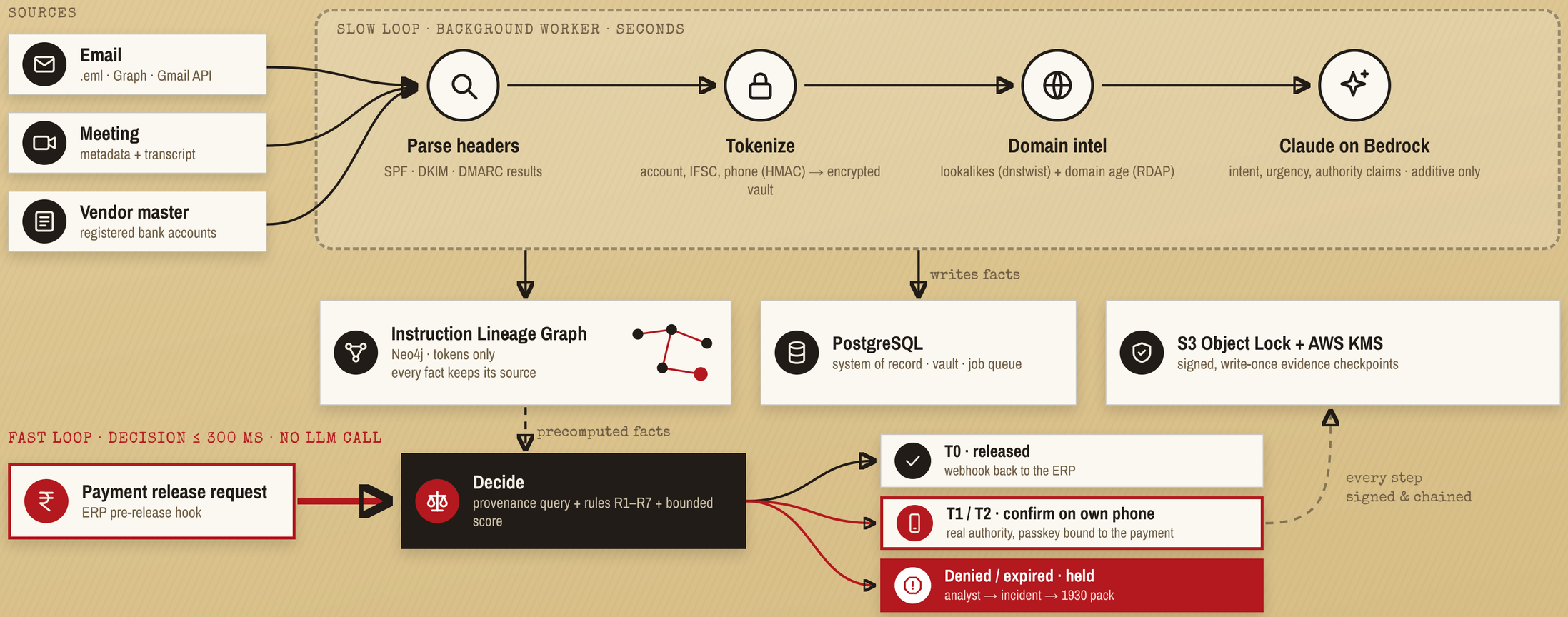
The detector says “authentic”, the CFO denies on their phone, the payment is held, the 1930 pack is generated.

Detectors tell you a call might be fake. VeriFi makes sure money can’t move because of it.

CASE CLOSED
money never moved

ARCHITECTURAL OVERVIEW · END-TO-END SYSTEM, INPUTS, DATA SOURCES, CONSENT & PROVENANCE

Two loops: slow ingestion, fast decision gate.

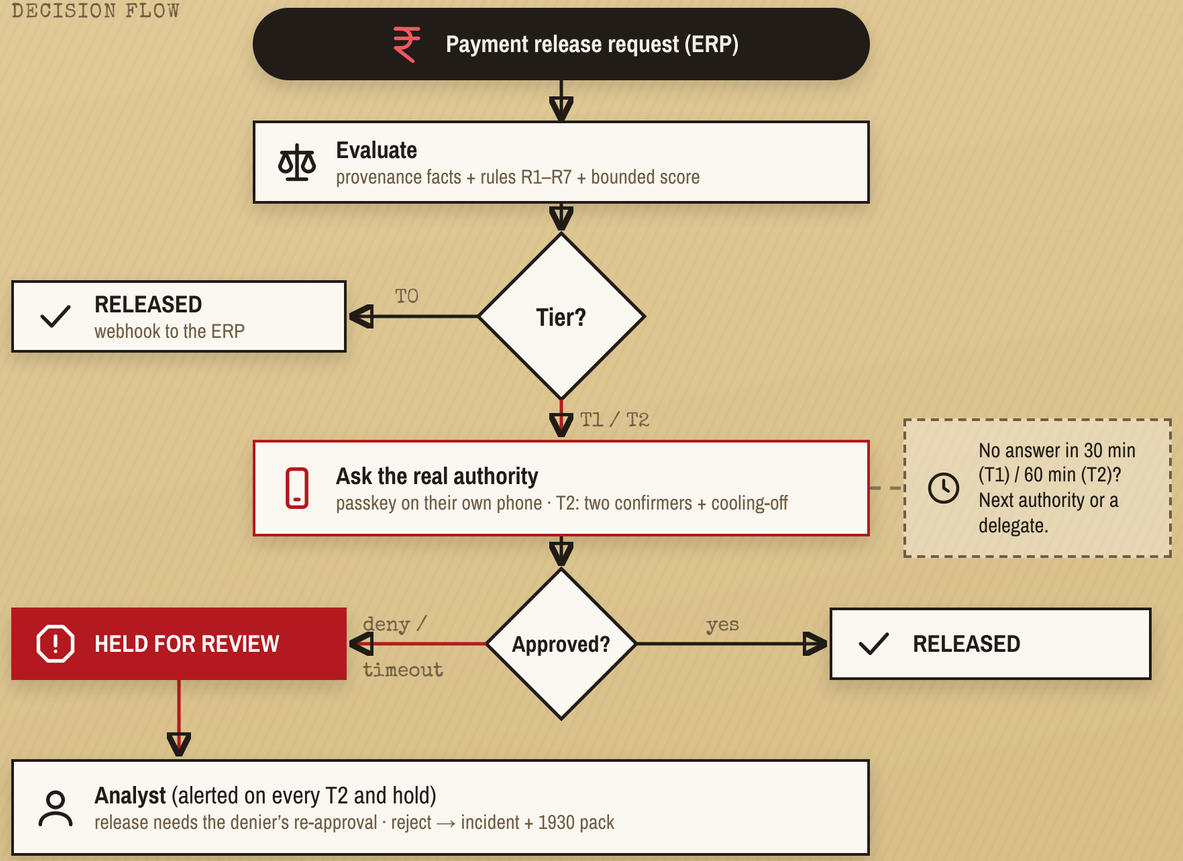


Consent & provenance: only customer-authorised finance mailboxes and meetings are ingested, under a DPA (the prototype uses synthetic data). Every graph fact keeps its source message and time; raw identifiers never leave the vault.

ARCHITECTURAL OVERVIEW · COMPONENTS, MODELS & RULES, DECISION FLOW & ESCALATION

How a payment moves, and what decides it.

DECISION FLOW



COMPONENTS

Ingestion worker

USES Header parser, Presidio + Indian recognizers, dnstwist, RDAP
STORES S3 (raw, 90 days), vault
I/O Postgres job queue → graph facts

LLM extractor

USES Claude on Amazon Bedrock, JSON-schema output, additive only
STORES nothing
I/O Bedrock API → intent, urgency, authority claims

Provenance service

USES Cypher path queries (account → source)
STORES Neo4j
I/O internal → facts per account

Policy engine

USES Rules R1–R7 + bounded score, versioned YAML
STORES Postgres
I/O pure function → tier + reasons

Confirmation service

USES WebAuthn (py_webauthn), approval matrix
STORES Postgres
I/O REST + approver app → signed decision

Evidence service

USES SHA-256 chain, KMS ECDSA signatures
STORES Postgres + S3 Object Lock
I/O REST + CLI verifier → verifiable record, incident pack

INTERFACES & DEPLOYMENT

ERP POST /v1/payments/evaluate (HMAC) · signed webhooks
Audit GET /v1/evidence/verify · CLI verifier
Sources POST /v1/ingest/email · /v1/ingest/meeting
People approver app (passkey) · analyst console
Deploy API + worker container, Postgres, Neo4j AuraDB, S3 / KMS, Bedrock (AWS Mumbai)

ARCHITECTURAL OVERVIEW · HUMAN REVIEW, EVIDENCE, SECURITY, PERFORMANCE & DISCLOSURES

Humans decide, every step is signed, failures are safe.

Evidence path · tamper-evident by design

#41
Decision · T2
prev 77d0…19b4
hash 4c1e…a07f

#42
CFO deny · passkey
prev 4c1e…a07f
hash 9b33…e21c

#43
Payment held
prev 9b33…e21c
hash e5a2…c8d1

✓ KMS
Signed checkpoint
head e5a2…c8d1
→ S3 Object Lock

- Checkpoints at least every 15 min and on every hold
- Write-once storage; KMS ECDSA signatures
- Verifier recomputes the chain and every passkey signature: one changed byte → BROKEN

Human review, notifications & reporting

Approver app
pending requests · polling → Web Push · SMS carries only a link

→

Analyst queue
by tier, amount, age · release / reject with a written reason

→

1930 playbook
call 1930 if money left · file at cybercrime.gov.in · block domain · alert the executive

Signed webhooks tell the ERP: **released · held · rejected**

Forged / replayed passkey
✓ py_webauthn checks; single-use challenge

Rogue enrollment
✓ One-time admin link; user alerted; 2 admins

Prompt injection
✓ LLM off the decision path; additive only

Lookalike passes SPF / DKIM
✓ dnstwist variants + domain age

Alert flooding
✓ Signals tied to the paid account

Outage / data leak
✓ Fail-safe step-up; tokens; tenant isolation

PERFORMANCE

≤ 300 ms decision p95 · **< 60 s** ingestion lag · **< 60 s** median confirm · **< 3%** step-up rate

Validated by a load test, 14 red-team regressions, 7 scenarios with exact expected scores, an LLM eval set, and a 60-day shadow-mode pilot.

DISCLOSURES · AI-GENERATED CONTENT, DATASETS, MODELS & THIRD-PARTY ASSETS

AI-generated content
This deck, its diagrams, our design documents and the product film (visuals and its original synthesized soundtrack) were made with AI assistance (Anthropic Claude, via Claude Code) and reviewed and edited by the team. Worked-example scores are computed, not estimated.

Datasets
Synthetic only: Kestrel Infra Ltd, its people, vendors, emails, meetings and payments are fictional. Public: news reporting on the Arup case. No confidential bank, customer or platform data. No dataset is used for training.

Models
Claude on Amazon Bedrock (anthropic.claude-opus-5-5) for text extraction only; nothing is trained or fine-tuned. Detector-agnostic by design: the deepfake score is a labelled simulated input, and any detector can plug in as one weak signal.

Third-party assets
Open source: FastAPI, Next.js, Neo4j, PostgreSQL, py_webauthn, SimpleWebAuthn, Microsoft Presidio, dnstwist, Cytoscape.js. Cloud: AWS Bedrock, S3, KMS. Fonts: Archivo Narrow, Special Elite, Saira Stencil One, Caveat (Google Fonts, SIL OFL). Icons drawn by us. No stock footage or music.

Sources: Arup case: South China Morning Post (May 2024), Construction Briefing (2024). RBI beneficiary name lookup for NEFT / RTGS: RBI circular, 30 Dec 2024 (effective 1 Apr 2025). DPDP Rules 2025: notified Nov 2025 (Hogan Lovells; AZB & Partners summaries). Competitor descriptions are from public product positioning, as of Oct 2026.